

Domain: Deliver, Service and Support Management Objective: DSS05 - Managed Security Services		Focus Area: COBIT Core Model
Description		
Protect enterprise information to maintain the level of information security risk acceptable to the enterprise in accordance with the security policy. Establish and maintain information security roles and access privileges. Perform security monitoring.		
Purpose		
Minimize the business impact of operational information security vulnerabilities and incidents.		
The management objective supports the achievement of a set of primary enterprise and alignment goals:		
Enterprise Goals	➔	Alignment Goals
• EG02 Managed business risk • EG06 Business service continuity and availability		• AG02 Managed I&T-related risk • AG07 Security of information, processing infrastructure and applications, and privacy
Example Metrics for Enterprise Goals		Example Metrics for Alignment Goals
EG02 a. Percent of critical business objectives and services covered by risk assessment b. Ratio of significant incidents that were not identified in risk assessments vs. total incidents c. Frequency of updating risk profile		AG02 a. Frequency of updating risk profile b. Percent of enterprise risk assessments including I&T-related risk c. Number of significant I&T-related incidents that were not identified in a risk assessment
EG06 a. Number of customer service or business process interruptions causing significant incidents b. Business cost of incidents c. Number of business processing hours lost due to unplanned service interruptions d. Percent of complaints as a function of committed service availability targets		AG07 a. Number of confidentiality incidents causing financial loss, business disruption or public embarrassment b. Number of availability incidents causing financial loss, business disruption or public embarrassment c. Number of integrity incidents causing financial loss, business disruption or public embarrassment

A. Component: Process		
Management Practice	Example Metrics	
DSS05.01 Protect against malicious software. Implement and maintain preventive, detective and corrective measures (especially up-to-date security patches and virus control) across the enterprise to protect information systems and technology from malicious software (e.g., ransomware, malware, viruses, worms, spyware, spam).	a. Number of successful malicious software attacks b. Percent of employees failing tests on malicious attacks (e.g., test of phishing email)	
Activities		Capability Level
1. Install and activate malicious software protection tools on all processing facilities, with malicious software definition files that are updated as required (automatically or semi-automatically).		2
2. Filter incoming traffic, such as email and downloads, to protect against unsolicited information (e.g., spyware, phishing emails).		
3. Communicate malicious software awareness and enforce prevention procedures and responsibilities. Conduct periodic training about malware in email and Internet usage. Train users to not open, but report, suspicious emails and to not install shared or unapproved software.		3
4. Distribute all protection software centrally (version and patch-level) using centralized configuration and IT change management.		
5. Regularly review and evaluate information on new potential threats (e.g., reviewing vendors' products and services security advisories).		4
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
CMMI Cybermaturity Platform, 2018	DP:DC Detect Malicious Code; RI:VT Vulnerability and Threat Identification	
HITRUST CSF version 9, September 2017	09.04 Protection Against Malicious & Mobile Code	
ISF, The Standard of Good Practice for Information Security 2016	TS1 Security Solutions	
ISO/IEC 27002:2013/Cor.2:2015(E)	12.2 Protection against malware	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 4: Continuous Vulnerability Assessment and Remediation; CSC 8: Malware Defenses	

A. Component: Process (cont.)	
Management Practice	Example Metrics
DSS05.02 Manage network and connectivity security. Use security measures and related management procedures to protect information over all methods of connectivity.	a. Number of firewall breaches b. Number of vulnerabilities discovered c. Percent of time network and systems not available due to security incident
Activities	Capability Level
1. Allow only authorized devices to have access to corporate information and the enterprise network. Configure these devices to force password entry.	2
2. Implement network filtering mechanisms, such as firewalls and intrusion detection software. Enforce appropriate policies to control inbound and outbound traffic.	
3. Apply approved security protocols to network connectivity.	
4. Configure network equipment in a secure manner.	
5. Encrypt information in transit according to its classification.	3
6. Based on risk assessments and business requirements, establish and maintain a policy for security of connectivity.	
7. Establish trusted mechanisms to support the secure transmission and receipt of information.	
8. Carry out periodic penetration testing to determine adequacy of network protection.	4
9. Carry out periodic testing of system security to determine adequacy of system protection.	
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference
CMMI Cybermaturity Platform, 2018	AC.MI Manage Network Integrity & Segregation; CM.MN Monitor Networks; AC.CP Manage Communication Protections
HITRUST CSF version 9, September 2017	01.04 Network Access Control
ISF, The Standard of Good Practice for Information Security 2016	PA2.3 Mobile Device Connectivity; NC1.1 Network Device Configuration
ISO/IEC 27002:2013/Cor.2:2015(E)	13.1 Network security management
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Draft), August 2017	3.20 System and information integrity (SI-8)
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 9: Limitation and Control of Network Ports, Protocols, and Services; CSC 11: Secure Configurations for Network Devices such as Firewalls, Routers, and Switches
Management Practice	Example Metrics
DSS05.03 Manage endpoint security. Ensure that endpoints (e.g., laptop, desktop, server, and other mobile and network devices or software) are secured at a level that is equal to or greater than the defined security requirements for the information processed, stored or transmitted.	a. Number of incidents involving endpoint devices b. Number of unauthorized devices detected on the network or in the end-user environment c. Percent of individuals receiving awareness training relating to use of endpoint devices
Activities	Capability Level
1. Configure operating systems in a secure manner.	2
2. Implement device lockdown mechanisms.	
3. Manage remote access and control (e.g., mobile devices, teleworking).	
4. Manage network configuration in a secure manner.	
5. Implement network traffic filtering on endpoint devices.	
6. Protect system integrity.	
7. Provide physical protection of endpoint devices.	
8. Dispose of endpoint devices securely.	
9. Manage malicious access through email and web browsers. For example, block certain websites and deactivate click-through on links for smartphones.	
10. Encrypt information in storage according to its classification.	3

CHAPTER 4

COBIT GOVERNANCE AND MANAGEMENT OBJECTIVES—DETAILED GUIDANCE

A. Component: Process (cont.)		
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
CMMI Cybermaturity Platform, 2018	IPMM Apply Mobile Device Management; TPMP Apply Media Protection; DPDP Detect Mobile Code and Browser Protection	
ISF, The Standard of Good Practice for Information Security 2016	PM1.3 Remote Working; PA2.1 Mobile Device Configuration; PA2.4 Employee-owned Devices; PA2.5 Portable Storage Devices; NC1.6 Remote Maintenance	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Draft), August 2017	3.4 Assessment, authorization and monitoring (CA-8, CA-9); 3.19 System and communications protection (SC-10)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 3: Secure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers; CSC 7: Email and Web Browser Protections	
Management Practice	Example Metrics	
DSS05.04 Manage user identity and logical access. Ensure that all users have information access rights in accordance with business requirements. Coordinate with business units that manage their own access rights within business processes.	a. Average time between change and update of accounts b. Number of accounts (vs. number of authorized users/staff) c. Number of incidents relating to unauthorized access to information	
Activities	Capability Level	
1. Maintain user access rights in accordance with business function, process requirements and security policies. Align the management of identities and access rights to the defined roles and responsibilities, based on least-privilege, need-to-have and need-to-know principles.	2	
2. Administer all changes to access rights (creation, modifications and deletions) in a timely manner based only on approved and documented transactions authorized by designated management individuals.	3	
3. Segregate, reduce to the minimum number necessary and actively manage privileged user accounts. Ensure monitoring on all activity on these accounts.		
4. Uniquely identify all information processing activities by functional roles. Coordinate with business units to ensure that all roles are consistently defined, including roles that are defined by the business itself within business process applications.		
5. Authenticate all access to information assets based on the individual's role or business rules. Coordinate with business units that manage authentication within applications used in business processes to ensure that authentication controls have been properly administered.		
6. Ensure that all users (internal, external and temporary) and their activity on IT systems (business application, IT infrastructure, system operations, development and maintenance) are uniquely identifiable.		
7. Maintain an audit trail of access to information depending upon its sensitivity and regulatory requirements.	4	
8. Perform regular management review of all accounts and related privileges.		
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
HITRUST CSF version 9, September 2017	10.03 Cryptographic Controls	
ISF, The Standard of Good Practice for Information Security 2016	PM1.1 Employment Life Cycle; SA1 Access Management	
ISO/IEC 27002:2013/Cor.2:2015(E)	7.3 Termination and change of employment; 9. Access control	
ITIL V3, 2011	Service Operation, 4.5 Access Management	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Draft), August 2017	3.1 Access control (AC-11, AC-12); 3.11 Media protection (MP-2, MP-4, MP-7); 3.13 Physical and environmental protection (PE-2, PE-3, PE-6)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 1: Inventory of Authorized and Unauthorized Devices; CSC 2: Inventory of Authorized and Unauthorized Software; CSC 5: Controlled Use of Administrative Privileges; CSC 16: Account Monitoring and Control	

COBIT® 2019 FRAMEWORK: GOVERNANCE AND MANAGEMENT OBJECTIVES

A. Component: Process (cont.)		
Management Practice	Example Metrics	
DSS05.05 Manage physical access to I&T assets. Define and implement procedures (including emergency procedures) to grant, limit and revoke access to premises, buildings and areas, according to business need. Access to premises, buildings and areas should be justified, authorized, logged and monitored. This requirement applies to all persons entering the premises, including staff, temporary staff, clients, vendors, visitors or any other third party.	a. Average rating for physical security assessments b. Number of physical information security-related incidents	
Activities	Capability Level	
1. Log and monitor all entry points to IT sites. Register all visitors, including contractors and vendors, to the site.	2	
2. Ensure all personnel display properly approved identification at all times.		
3. Require visitors to be escorted at all times while on-site.		
4. Restrict and monitor access to sensitive IT sites by establishing perimeter restrictions, such as fences, walls and security devices on interior and exterior doors.		
5. Manage requests to allow appropriately authorized access to the computing facilities.	3	
6. Ensure that access profiles remain current. Base access to IT sites (server rooms, buildings, areas or zones) on job function and responsibilities.		
7. Conduct regular physical information security awareness training.		
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
CMMI Cybermaturity Platform, 2018	AC.MA Manage Access; ID.DI Determine Impacts	
HITRUST CSF version 9, September 2017	01.01 Business Requirement for Access Control; 01.02 Authorized Access to Information Systems; 02.0 Human Resources Security	
ISF, The Standard of Good Practice for Information Security 2016	NC1.2 Physical Network Management	
ISO/IEC 27002:2013/Cor.2:2015(E)	11. Physical and environmental security	
Management Practice	Example Metrics	
DSS05.06 Manage sensitive documents and output devices. Establish appropriate physical safeguards, accounting practices and inventory management regarding sensitive I&T assets, such as special forms, negotiable instruments, special-purpose printers or security tokens.	a. Number of stolen output devices b. Percent of sensitive documents and output devices identified in inventory	
Activities	Capability Level	
1. Establish procedures to govern the receipt, use, removal and disposal of sensitive documents and output devices into, within, and outside of the enterprise.	2	
2. Ensure cryptographic controls are in place to protect sensitive electronically stored information.		
3. Assign access privileges to sensitive documents and output devices based on the least-privilege principle, balancing risk and business requirements.	3	
4. Establish an inventory of sensitive documents and output devices, and conduct regular reconciliations.		
5. Establish appropriate physical safeguards over sensitive documents.		

CHAPTER 4

COBIT GOVERNANCE AND MANAGEMENT OBJECTIVES—DETAILED GUIDANCE

A. Component: Process (cont.)		
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
CMMI Cybermaturity Platform, 2018	CM.Ph Monitor Physical	
HITRUST CSF version 9, September 2017	01.06 Application & Information Access Control; 01.07 Mobile Computing & Teleworking; 08.0 Physical & Environmental Security; 10.03 Cryptographic Controls; 10.04 Security of System Files	
ISF, The Standard of Good Practice for Information Security 2016	IR2.3 Business Impact Assessment - Confidentiality Requirements; IR2.4 Business Impact Assessment - Integrity Requirements; IR2.5 Business Impact Assessment - Availability Requirements; IM2.2 Sensitive Physical Information; PA2.2 Enterprise Mobility Man	
ISO/IEC 27002:2013/Cor.2:2015(E)	10. Cryptography	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Draft), August 2017	3.1 Access control (AC-2, AC-3, AC-4, AC-5, AC-6, AC-13, AC-24); 3.7 Identification and authentication (IA-2, IA-10, IA-11)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	CSC 15: Wireless Access Control	
Management Practice	Example Metrics	
DSS05.07 Manage vulnerabilities and monitor the infrastructure for security-related events. Using a portfolio of tools and technologies (e.g., intrusion detection tools), manage vulnerabilities and monitor the infrastructure for unauthorized access. Ensure that security tools, technologies and detection are integrated with general event monitoring and incident management.	a. Number of vulnerability tests carried out on perimeter devices b. Number of vulnerabilities discovered during testing c. Time taken to remediate any vulnerabilities d. Percent of tickets created in a timely manner when monitoring systems identify potential security incidents	
Activities	Capability Level	
1. Continually use a portfolio of supported technologies, services and assets (e.g., vulnerability scanners, fuzzers and sniffers, protocol analyzers) to identify information security vulnerabilities.	2	
2. Define and communicate risk scenarios, so they can be easily recognized, and the likelihood and impact understood.		
3. Regularly review the event logs for potential incidents.		
4. Ensure that security-related incident tickets are created in a timely manner when monitoring identifies potential incidents.		
5. Log security-related events and retain records for appropriate period.	3	
Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference	
ISF, The Standard of Good Practice for Information Security 2016	IR2.6 Threat Profiling	
National Institute of Standards and Technology Special Publication 800-53, Revision 5 (Draft), August 2017	3.7 Identification and authentication (IA-3); 3.11 Media protection (MP-1); 3.13 Physical and environmental protection (PE-5); 3.19 System and communications protection (SC-15)	
The CIS Critical Security Controls for Effective Cyber Defense Version 6.1, August 2016	Maintenance, Monitoring, and Analysis of Audit Logs	

C. Component: Information Flows and Items (see also Section 3.6) (cont.)				
Management Practice	Inputs		Outputs	
DSS05.05 Manage physical access to I&T assets.	From	Description	Description	To
			Access logs	DSS06.03, MEA04.07
			Approved access requests	Internal
DSS05.06 Manage sensitive documents and output devices.	AP003.02	Information architecture model	Access privileges	Internal
			Inventory of sensitive documents and devices	Internal
DSS05.07 Manage vulnerabilities and monitor the infrastructure for security-related events.			Security incident tickets	DSS02.02
			Security incident characteristics	Internal
			Security event logs	Internal
Related Guidance (Standards, Frameworks, Compliance Requirements)		Detailed Reference		
No related guidance for this component				

D. Component: People, Skills and Competencies		
Skill	Related Guidance (Standards, Frameworks, Compliance Requirements)	Detailed Reference
Information security	Skills Framework for the Information Age V6, 2015	SCTY
Information security management	e-Competence Framework (e-CF)—A common European Framework for ICT Professionals in all industry sectors—Part 1: Framework, 2016	E. Manage—E.8. Information Security Management
Penetration testing	Skills Framework for the Information Age V6, 2015	PENT
Security administration	Skills Framework for the Information Age V6, 2015	SCAD

E. Component: Policies and Procedures			
Relevant Policy	Policy Description	Related Guidance	Detailed Reference
Information security policy	Sets guidelines to protect corporate information and associated systems and infrastructure.		

F. Component: Culture, Ethics and Behavior		
Key Culture Elements	Related Guidance	Detailed Reference
Create a culture of awareness regarding user responsibility to maintain security and privacy practices.	1) HITRUST CSF version 9, September 2017; (2) ISF, The Standard of Good Practice for Information Security 2016	(1) 01.03 User Responsibilities; (2) PM2.1 Security Awareness Program

G. Component: Services, Infrastructure and Applications	
• Directory services • Email filtering systems • Identity and access management system • Security awareness services • Security information and event management (SIEM) tools • Security operations center (SOC) services • Third-party security assessment services • URL filtering systems	